

Graduação

Tecnologia em Redes de computadores

Sistemas Operacionais Abertos III

Prof. Reinaldo Freitas

Agenda

- Introdução
- TCP Wrapper
- SELinux
- Servidor Proxy
- TCP Syslog
- Detecção de intrusos
- Módulos PAM
- LDAP



Fecomércio RJ

Sesc | Senac

TCP Wrapper

TCP Wrappers

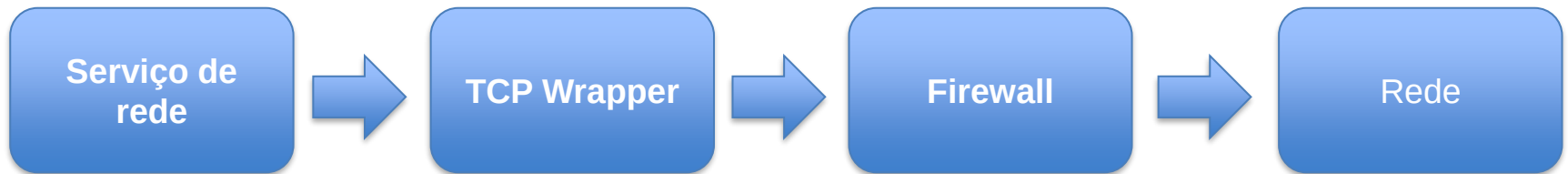
Definição

- É um recurso utilizado para controlar quem pode acessar serviços em uma máquina. Baseia-se na utilização dos arquivos **/etc/hosts.allow** e **/etc/hosts.deny**, onde o primeiro determina quem pode acessar a máquina e o segundo quem não pode.
- Se um host corresponder a uma regra contida no arquivo **/etc/hosts.allow**, o acesso será liberado e o arquivo **/etc/hosts.deny** não será consultado. Desta forma, a ordem da regra nos arquivos é importante.
- Alterações nos arquivos tem efeito imediato sem a necessidade de reiniciar serviços de rede.
- Maiores informações podem ser obtidas no link abaixo:
https://access.redhat.com/documentation/en-us/red_hat_enterprise_linux/6/html/security_guide/sect-security_guide-tcp_wrappers_and_xinetd-tcp_wrappers_configuration_files

TCP Wrappers

Definição

- O TCP Wrapper está contido entre o serviço de rede e o firewall.



TCP Wrappers

Definição

- O formato dos arquivos **/etc/hosts.allow** e **/etc/hosts.deny** é o seguinte:

<serviço> : <host> [: <comando>]

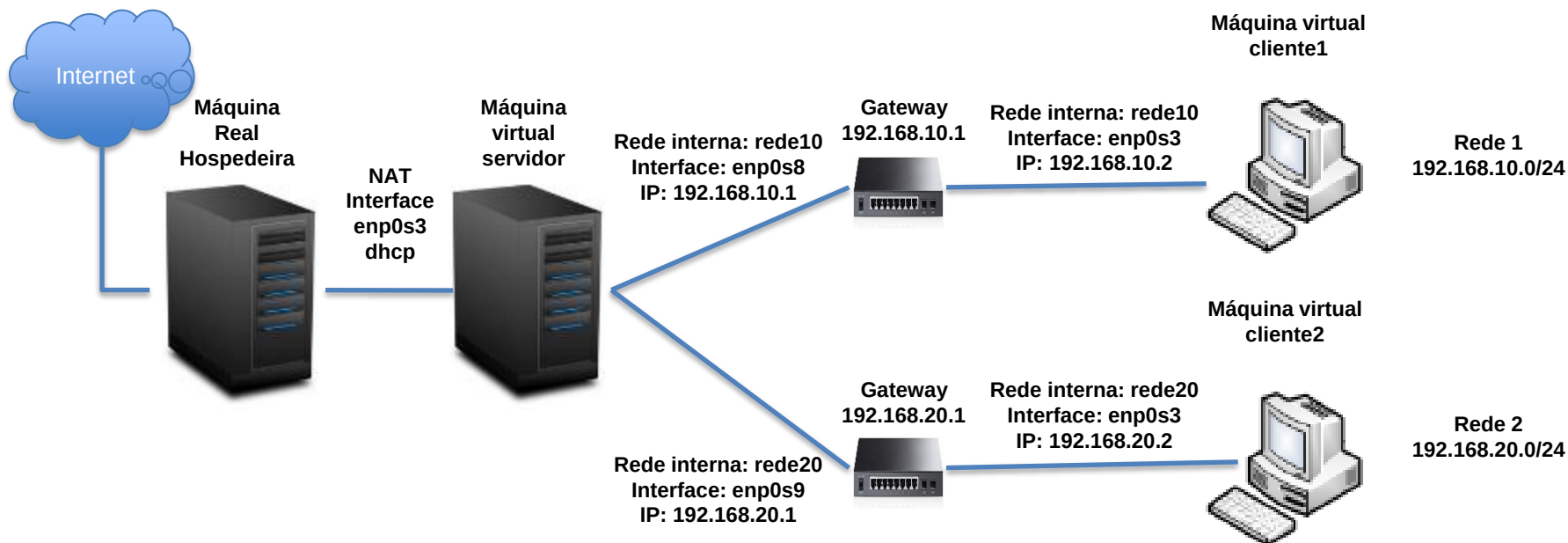
Onde:

- | | |
|-----------|--|
| <serviço> | Corresponde ao serviço que será liberado ou bloqueado. Pode ser utilizada a palavra ALL para se referenciar a todos os serviços. |
| <host> | Determina a(s) máquina(s) onde será aplicada a regra. . Pode ser utilizada a palavra ALL para se referenciar a todas as máquinas. |
| <comando> | Pode ser utilizado para determinar comandos a serem aplicados a regra. Os principais comandos são: allow (para liberar) e deny (para bloquear). O default é allow para o arquivo /etc/hosts.allow e deny para o arquivo /etc/hosts.deny. |

TCP Wrappers

Preparação de ambiente

Configure de forma persistente uma rede com 3 máquinas virtuais, sendo que uma servirá como um servidor e as outras duas serão clientes de redes distintas. Segue o desenho da rede:



TCP Wrappers

Configuração

- Para verificar se um serviço de rede suporta TCP Wrapper, utilize o comando **ldd**. O comando está contido no pacote **glibc-common**.

ldd <arquivo do serviço> | grep libwrap

- Por exemplo, utilize o comando abaixo para verificar se o serviço sshd suporta TCP Wrapper:

ldd /sbin/sshd | grep libwrap

TCP Wrappers

Configuração

- Como o serviço sshd suporta TCP Wrapper, edite o arquivo **/etc/hosts.allow** da forma abaixo para liberar todos os hosts da rede **192.168.20.0** para acessar o servidor via SSH:

sshd:192.168.20.*

- Edite também o arquivo **/etc/hosts.deny** da forma abaixo para bloquear o acesso ao servidor via SSH para todos os demais hosts.

sshd:all

TCP Wrappers

Teste de conexão

- Tente acessar o servidor via SSH a partir de um host contido na rede 192.168.10.0.

ssh root@192.168.10.1

- O acesso deve ser rejeitado pelo servidor.

TCP Wrappers

Teste de conexão

- Tente acessar o servidor via SSH a partir de um host contido na rede 192.168.20.0.

ssh root@192.168.20.1

- O acesso deve ser liberado pelo servidor.

TCP Wrappers

Teste de conexão

- Retire as configurações feitas nos arquivos **/etc/hosts.allow** e **/etc/hosts.deny**.
- Tente acessar o servidor via SSH a partir de hosts contido nas redes 192.168.10.0 e 192.168.20.0.

ssh root@192.168.10.1 (na rede 192.168.10.0)

ssh root@192.168.20.1 (na rede 192.168.20.0)

- Ambos acessos devem ser liberados pelo servidor.

TCP Wrappers

Exercícios:

- 1) Libere o acesso via SSH ao servidor apenas para os hosts da rede 192.168.10.0 e depois tente acessar o servidor via SSH através de outra rede.
- 2) Retire as configurações feitas através do TCP Wrapper e verifique se os bloqueios perderam o efeito.



Fecomércio RJ

Sesc | Senac

SELinux

Diferenças entre os controles de acesso

- **DAC (*Discretionary Access Control*):** O acesso a um determinado objeto ou arquivo baseia-se nas permissões definidas para o proprietário desse objeto, para os grupos e para os outros. O problema maior é que o proprietário de um objeto tem o controle das configurações de segurança desse objeto. Também não é possível definir direitos de acesso para os aplicativos do sistema. É o controle de acesso básico do Linux.
- **MAC (*Mandatory Access Control*):** O proprietário de um objeto não pode alterar as configurações de segurança desse objeto, pois as configurações são realizadas por uma pessoa/equipe responsável.
- **RBAC (*Role Based Access Control* - RBAC):** Mantém as principais características do MAC acrescentando a função de controle de acesso por papéis e não mais por sujeitos (usuário ou processo). É uma versão refinada do MAC.

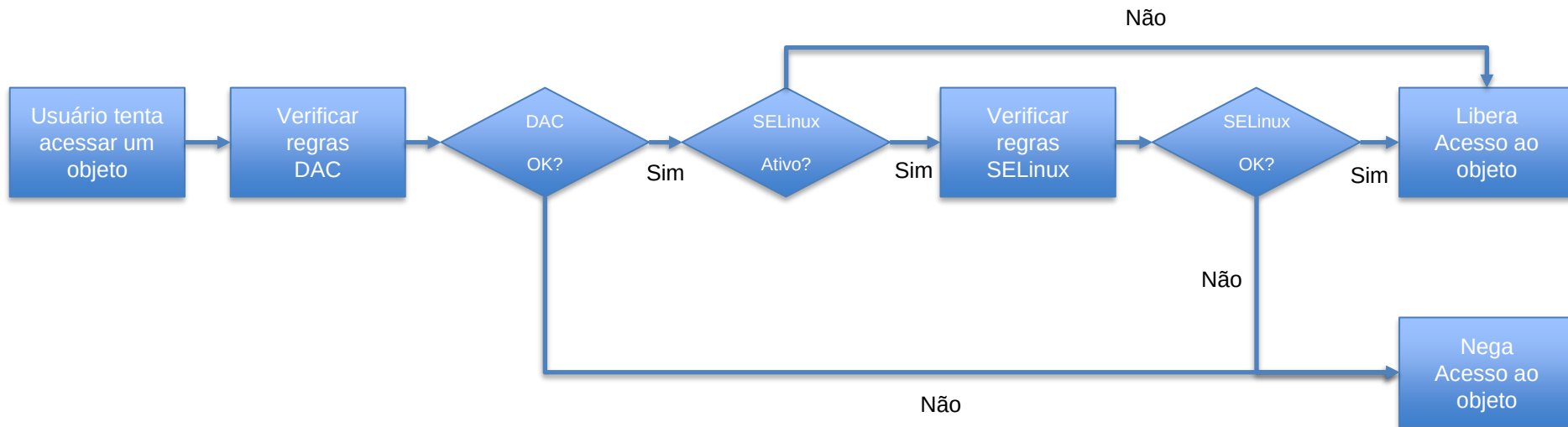
SELinux

SELinux

- SELinux (*Security Enhanced Linux*) é um módulo de segurança reforçado do Linux desenvolvido pela NSA (*National Security Agency*) juntamente com outras organizações de pesquisa de segurança;
- Ele oferece melhor segurança para o sistema Linux via controle de acesso baseado em papéis (RBAC), em sujeitos e objetos (conhecidos como processos e recursos).
- Maiores informações podem ser obtidas no link abaixo:
https://access.redhat.com/documentation/en-us/red_hat_enterprise_linux/7/html/selinux_users_and_administrators_guide/index

SELinux

Etapas para liberação de acesso



SELinux

Status do SELinux

- Utilize o comando **sestatus** para visualizar o modo de operação (modo ativo em memória) e o modo como está configurado o arquivo de configuração do SELinux (modo ativo após a reinicialização do sistema).

sestatus

SELinux

Status do SELinux

- Utilize o comando **getenforce** para visualizar apenas o modo de operação ativo.

getenforce

SELinux

Desativar o SELinux

- Utilize o comando **setenforce** para alterar o modo de operação das regras da política de segurança do SELinux. Sintaxe:

setenforce [opções]

Onde as opções são:

- ☐ 0 ou permissive Desativa temporariamente as regras, mas continua gerando logs.
 - ☐ 1 ou enforcing Ativa temporariamente as regras.
- Para desativar as regras de forma definitiva, altere o arquivo **/etc/selinux/config** alterando a opção **SELINUX** de **enforcing** para **disabled**. Esta alteração só terá efeito quando o sistema for reinicializado.

SELinux

LOG

- Consulte o arquivo **/var/log/audit.log** para visualizar as últimas mensagens geradas pelo SELinux. É necessário que o serviço **auditd** esteja em execução.

tail /var/log/audit/audit.log

- Para verificar os erros no log de uma forma mais legível, inclusive com indicações de soluções para os problemas, execute o comando abaixo. O comando está contido no pacote **polycoreutils-python**.

audit2allow -a -w

SELinux

Booleanos

- Eles são opções que alteram o comportamento da política do SELinux. Podem ser habilitados ou desabilitados. Utilize o comando **getsebool** para visualizar o valor de um booleano. A opção **-a** lista todos os booleanos.

getsebool [-a] [nome do booleano]

SELinux

Booleanos

- Pode-se utilizar o comando **setsebool** para configurar um booleano.

setsebool [-P] <nome do booleano> [on | off]

- A opção -P configura o booleano de forma permanente.

Instalação dos pacotes do Samba

- No **Red Hat** utilize o comando **yum** da forma abaixo para instalar os principais pacotes do Samba.

Sintaxe:

```
yum install samba samba-client
```

- O sistema já instalará as dependências destes pacotes;
- Os pacotes são pesquisados com base no diretório **/etc/yum.repos.d/** que contém vários arquivos **.repo**. Esse é o local padrão para arquivos **.repo**, mas outros locais podem ser especificados no arquivo de configuração do **yum**, que normalmente é o **/etc/yum.conf**;
- Pode ser utilizado o comando **cat** para listar o conteúdo de um dos arquivos **.repo**.

SELinux

Iniciação dos serviços

- Inicie o serviço **smb** do Samba.

systemctl start smb

Configuração

- A configuração do compartilhamento de arquivos no Samba é feito no arquivo **smb.conf**, localizado normalmente na pasta **/etc/samba**;
- Se estiver utilizando uma máquina virtual, configure a rede da máquina virtual para ficar no modo **Bridge**, de forma que seja gerado um ip para a máquina virtual diferente da máquina hospedeira.
- Verifique o ip da interface enp0s3 no servidor para confirmar que ela está na mesma rede da máquina Windows.

ip addr show enp0s3

SELinux

Criar uma pasta para ser compartilhada

- Através do comando `mkdir`, crie a pasta a ser compartilhada.

`mkdir -p /samba/teste`

- Altere as permissões da pasta criada de forma que todos os usuários tenha acesso total a ela.

`chmod -R 777 /samba/teste`

Configuração geral do arquivo smb.conf

- Edite o arquivo **/etc/samba/smb.conf** de forma a alterar os parâmetros conforme as informações destacadas abaixo:

[global]

workgroup = SAMBA
security = user
passdb backend = tdbsam
map to guest = bad user

[homes]

comment = Pasta home dos usuários
valid users = %S, %D%w%S
browseable = yes
read only = no

[teste]

comment = Pasta pública compartilhada
guest ok = yes
read only = no
browseable = yes
path = /samba/teste

SELinux

Testar a configuração do Samba

- Utilize o comando **testparm** para verificar se existe algum erro no arquivo **smb.conf**.

testparm

SELinux

Reinicializar o serviço do Samba

- Como o arquivo **smb.conf** foi alterado, utilize o comando **systemctl** para reinicializar o serviço do Samba.

systemctl restart smb

SELinux

Ativar o Samba no firewall pela linha de comando

- Pode ser utilizado o comando `firewall-cmd`. Este comando está contido no pacote **firewalld**.

```
firewall-cmd --permanent --add-service=samba  
firewall-cmd --reload
```

- Utilize o comando abaixo para listar os serviços ativos:
- **firewall-cmd --list-services**

SELinux

Teste da configuração

- Com o SELinux ativo, tente acessar o compartilhamento criado no Samba através do Explorer do Windows digitando na barra de pesquisa:

`\\<ip do servidor linux>\teste`

- O compartilhamento não deverá estar acessível porque o SELinux bloqueará o acesso.

SELinux

Teste da configuração

- Para verificar o erro no log de uma forma mais legível, inclusive com indicações de soluções para os problemas, execute o comando abaixo. O comando está contido no pacote **polycoreutils-python**.

audit2allow -a -w

- Se o erro não aparecer no log, é provável que o erro não tenha sido por conta do SELinux.

SELinux

Teste da configuração

- Se o erro não apareceu no log, utilize o comando **smbclient** a partir da máquina cliente1 para testar o acesso a pasta compartilhada pelo Samba.

smbclient -U root //192.168.10.1/teste

- Deve dar erro no acesso. Execute novamente a verificação do log.

audit2allow -a -w

SELinux

Teste da configuração

- Desative o SELinux temporariamente com o comando abaixo:

setenforce 0

SELinux

Teste da configuração

- Com o SELinux desativado, tente acessar novamente o compartilhamento criado no Samba através do Explorer do Windows digitando na barra de pesquisa:

\\<ip do servidor linux>\teste

- O compartilhamento deverá estar acessível porque o SELinux está desativado.

SELinux

Teste da configuração

- Caso tenha interesse em eliminar o compartilhamento feito no Windows, através do Prompt de Comando do Windows (Todos os Programas -> Acessórios -> Prompt de Comando) digite o seguinte comando:

net use \\<ip do servidor linux>\teste /delete

- Pode ser necessário esperar um pouco pelo *refresh* da rede. Utilize o comando abaixo para ver todas as conexões de rede:

net use

SELinux

Teste da configuração

- Se o acesso não funcionou pelo Windows, utilize o comando **smbclient** a partir da máquina cliente1 para testar o acesso a pasta compartilhada pelo Samba.

smbclient -U root //192.168.10.1/teste

- Ao entrar no *prompt* do comando, execute os seguintes comandos:

pwd

ls

quit

SELinux

Teste da configuração

- Ative novamente o SELinux com o comando abaixo:

setenforce 1

Configuração de booleanos

- No Samba, uma das configurações necessárias é a alteração dos seus booleanos. Os booleanos configuram quais arquivos e diretórios do servidor Samba poderão ser lidos ou gravados;
- Pode ser também ser utilizado o comando **semanage** para listar os booleanos associados ao Samba. Ele também está contido no pacote **polycoreutils-python**.

semanage boolean -l | grep -i samba

Configuração de booleanos

- Seguem alguns booleanos do Samba:
 - ☐ **samba_enable_home_dirs:** Permite que o Samba compartilhe o diretório inicial (Home) dos usuários.
 - ☐ **samba_export_all_ro:** Permite que o Samba compartilhe arquivos e diretórios de sistema como somente leitura.
 - ☐ **samba_export_all_rw:** Permite que o Samba compartilhe arquivos e diretórios de sistema como leitura / gravação.
 - ☐ **samba_domain_controller:** Permite que o Samba atue como controlador de domínio, adicione usuários / grupos e altere senhas.

SELinux

Configuração de booleanos

- Execute o comando abaixo para habilitar o compartilhamento dos diretórios do sistema com permissão de leitura e escrita.

setsebool -P samba_export_all_rw on

SELinux

Teste da configuração do booleano

- Com o SELinux ativo, tente acessar o compartilhamento no servidor Samba digitando na barra de pesquisa do Explorer do Windows a seguinte informação:

\\<ip do servidor Linux>\teste

- O compartilhamento deverá estar acessível porque o booleano do SELinux foi ativado.

Teste da configuração do booleano

- Se o acesso não funcionou pelo Windows, utilize o comando **smbclient** a partir da máquina cliente1 para testar o acesso a pasta compartilhada pelo Samba.

smbclient -U root //192.168.10.1/teste

- Ao entrar no *prompt* do comando, execute os seguintes comandos:

pwd

ls

quit

SELinux

Teste da configuração do booleano

- Grave um arquivo no diretório compartilhado através da janela que é aberta no Windows. Depois liste o diretório compartilhado no servidor para confirmar a gravação do arquivo

ls -la /samba/teste

SELinux

Teste da configuração do booleano

- Execute o comando abaixo para desabilitar a permissão de leitura e escrita do compartilhamento no Samba.

setsebool -P samba_export_all_rw off

SELinux

Contexto de Segurança

- É um conjunto de informações utilizado pela política do SELinux para determinar autorizações de acesso para um processo, usuário Linux ou arquivo. O contexto de segurança do SELinux é subdividido em:
 - ❑ Usuário SELinux (user): Identidade da política que é associada a um conjunto de papéis. Novos usuários Linux criados são associados por padrão ao usuário SELinux `unconfined_u`.
 - ❑ Papel (*role*): Papéis são definidos para domínios, e estes definem quais tipos de objetos podem ser acessados;
 - ❑ Tipo (*type*): Define um domínio para processos e um tipo para arquivos. É a parte mais utilizada do contexto de segurança.
 - ❑ Nível de segurança (*level* *syntax*): Formado pelo par sensibilidade e categoria.
- ❑ Utilize o comando `ls -Z <diretório>` para ver o contexto de segurança dos arquivos de um diretório. A listagem aparecerá no seguinte formato:
<permissões> <dono> <grupo> <papel> <nível de segurança> <arquivo>
- Pode ser utilizado o comando **runcon** para executar um programa em um determinado contexto de segurança.
- Maiores informações nos links abaixo:
https://access.redhat.com/documentation/en-us/red_hat_enterprise_linux/5/html/deployment_guide/rhlcommon-section-0085
https://access.redhat.com/documentation/en-us/red_hat_enterprise_linux/7/html/selinux_users_and_administrators_guide/chap-security-enhanced_linux-selinux_contexts

SELinux

Contexto de Segurança

- Utilize o comando abaixo para ver o contexto de segurança dos processos do usuário ativo no terminal ativo.

ps -Z

- Utilize o comando abaixo para ver o contexto de segurança dos arquivos contidos no diretório /samba/teste.

ls -Z /samba/teste

- Utilize o comando abaixo para ver o contexto de segurança do usuário ativo.

id -Z

SELinux

Contexto de Segurança

- Pode ser utilizado o comando **semanage** para listar a equivalência dos usuários do Linux com os usuários SELinux.

semanage login -l

- Para maiores informações consulte o link abaixo:

https://access.redhat.com/documentation/en-us/red_hat_enterprise_linux/8/html/using_selinux/managing-confined-and-unconfined-users_using-selinux

SELinux

Contexto de Segurança

- Pode ser utilizado o comando **semanage** para listar os usuários SELinux e seus respectivos papéis.

semanage user -l

SELinux

Configuração de contexto de segurança

- Pode-se utilizar o comando **semanage** para adicionar (opção -a) uma regra de contexto a um diretório ou arquivo. A opção -d exclui uma regra definida.

`semanage fcontext [-a | -d] -t <tipo de contexto> <diretório/arquivo>`

- A regra só será aplicada após a utilização do comando **restorecon**.
- Para maiores informações consulte o link abaixo:

https://access.redhat.com/documentation/en-us/red_hat_enterprise_linux/7/html/selinux_users_and_administrators_guide/sect-security-enhanced_linux-working_with_selinux-selinux_contexts_labeling_files

Configuração de contexto de segurança

- Utilize o comando abaixo para adicionar uma regra de contexto de segurança a uma pasta a ser compartilhada pelo Samba.

```
semanage fcontext -a -t samba_share_t "/samba/teste(/.*)?"
```

- O tipo **samba_share_t** permitirá o compartilhamento de arquivos e diretórios contidos na pasta **/samba/teste**.

Configuração de contexto de segurança

- Utilize o comando **restorecon** para aplicar a regra de contexto definida pelo comando **semanage**.

restorecon -R -v /samba/teste

- Os arquivos contidos no diretório e os que venham a ser criados assumirão o contexto definido.
- Crie um novo arquivo no diretório e verifique a regra de contexto aplicada a ele.

touch /samba/teste/novo_arquivo.txt

ls -Z /samba/teste

Configuração de contexto de segurança

- Também pode ser utilizado o comando **chcon** para a alteração da regras de contexto de segurança de arquivos e diretórios, mas as regras são perdidas após o boot do sistema ou da execução do comando restorecon. Execute o comando abaixo para alterar o contexto de segurança do arquivo novo_arquivo.txt no diretório /samba/teste.

```
chcon -R -t default_t /samba/teste/novo_arquivo.txt  
ls -Z /samba/teste
```

SELinux

Teste da configuração do contexto de segurança

- Com o SELinux ativo, acesse o compartilhamento criado no Samba através do Windows digitando:

\\<ip do servidor linux>\teste

- O compartilhamento estará acessível, mas o arquivo novo_arquivo.txt não, por conta da alteração do contexto de segurança do arquivo para **default_t**.

SELinux

Teste da configuração do contexto de segurança

- Se o acesso não funcionou pelo Windows, utilize o comando **smbclient** a partir da máquina cliente1 para testar o acesso a pasta compartilhada pelo Samba.

smbclient -U root //192.168.10.1/teste

- Ao entrar no *prompt* do comando, execute os seguintes comandos:

pwd

ls

quit

SELinux

Exercícios:

- 1) Instale o Apache no servidor através da instalação do pacote httpd.
- 2) Inicie o serviço httpd.
- 3) Grave um arquivo na pasta /var/www/html.
- 4) Liste o tipo do contexto de segurança do arquivo criado.
- 5) Com o SELinux ativo, execute o comando abaixo para baixar o arquivo gravado. Deverá ser possível baixá-lo para o diretório atual.

wget http://localhost/<nome do arquivo>

- 6) Altere o contexto de segurança do arquivo de forma que o tipo fique default_t. Liste novamente o contexto de segurança do arquivo.
- 7) Com o SELinux ainda ativo, execute novamente o comando abaixo para tentar baixar o arquivo gravado. Verifique que não será possível baixá-lo por conta da alteração do contexto de segurança.

wget http://localhost/<nome do arquivo>



Fecomércio RJ

Sesc | Senac

Servidor Proxy

Servidor Proxy

Conceito

- *Proxy* é um *gateway*, um sistema que pode analisar todas as camadas do pacote de rede e realizar ações baseadas em regras preestabelecidas.
- O *proxy web* mais utilizado no mundo Linux é o Squid.
- Nginx é outro servidor proxy conhecido no mundo Linux.

Servidor Proxy

Squid

- Ele pode bloquear o acesso baseado no domínio, URL, expressões regulares, usuário, IP de origem, IP de destino, dia da semana, hora, tipo de arquivo, tamanho, extensão de arquivo e uma infinidade de itens.
- Também pode fazer *cache* dos sites mais visitados aumentando a velocidade da internet do ponto de vista do usuário, pois economiza *link*.
- Maiores informações sobre Squid podem ser obtidas no link abaixo:

https://access.redhat.com/documentation/en-us/red_hat_enterprise_linux/7/html/networking_guide/sec-squid-install-run

Servidor Proxy

Squid - Instalação

- Para instalar o Squid utilize um dos comandos abaixo:

Para distribuições Red Hat:

yum install squid

Para distribuições Debian:

apt-get install squid

Servidor Proxy

Squid - Instalação

- Inicie o serviço e coloque-o para iniciar com o boot do sistema.

systemctl start squid

systemctl enable squid

- O arquivo de configuração do Squid é o **/etc/squid/squid.conf**.

Servidor Proxy

Configuração do servidor

- Seguem alguns parâmetros importantes do arquivo `/etc/squid/squid.conf`:

- ☐ **http_port** Define a porta utilizada. Normalmente é a porta 3128.
- ☐ **acl** Cria uma lista de controle de acesso (*Access Control List*). O parâmetro tem o seguinte formato:

acl <nome da acl> <tipo da acl> <lista de valores | arquivo >

Seguem os tipos e os valores que podem ser informados:

- ✓ **src**: IP, intervalo de IP ou rede de origem. O valor pode ser all para tudo.
- ✓ **dst**: IP, intervalo de IP ou rede de destino. O valor pode ser all para tudo.
- ✓ **dstdomain**: domínio (ex: facebook.com). O valor também pode ser o nome de um arquivo (entre aspas) que contenha os nomes dos domínios. Para informar vários domínios basta separá-los por um espaço.
- ✓ **url_regex**: expressão regular. O valor também pode ser o nome de um arquivo (entre aspas) que contenha as expressões regulares.
- ✓ **time**: Intervalo de hora. Ex: 12:00-12:59.
- ✓ **port**: Número de porta usada pelo site. Ex: 80.
- ✓ **proto**: Protocolo usado pelo site. Ex: http, ftp, etc.

Servidor Proxy

Configuração do servidor

☐ **http_access**

Define as acl's que estão liberadas ou bloqueadas. O parâmetro tem basicamente o seguinte formato: **http_access <allow | deny> [!] <lista de acl>**

Onde:

- ✓ **allow**: permitir.
- ✓ **deny**: negar.

OBS: O sinal ! tem o significado de “com exceção de” quando utilizado na frente de uma ACL.

☐ **cache_mem**

Limite de memória RAM a ser utilizado. Ex: 256 MB (default). Maiores informações entrar no link abaixo:

<https://wiki.squid-cache.org/SquidFaq/SquidMemory>

☐ **maximum_object_size_in_memory**

Tamanho máximo dos objetos mantidos em memória. Ex: 512 KB (default).

☐ **maximum_object_size**

Tamanho máximo para gravação no cache. Ex: 4 MB (default).

☐ **minimum_object_size**

Tamanho mínimo para gravação no cache. Ex: 0 KB (default).

Servidor Proxy

Configuração do servidor

☐ **access_log**

Nome do arquivo de LOG de requisições. Por default é o arquivo **/var/log/squid/access.log**.

☐ **cache_log**

Nome do arquivo de LOG do cache. Por default é o arquivo **/var/log/squid/cache.log**.

☐ **cache_dir**

Define o cache:

O parâmetro tem basicamente o seguinte formato:

cache_dir <tipo> <diretório> <tam> <L1> <L2>

Onde:

- ✓ **tipo**: tipo de armazenamento. Normalmente ufs.
- ✓ **tam**: tamanho do cache em Mbytes. Ex: 100 (default).
- ✓ **L1**: Número de subdiretórios no primeiro nível. Ex: 16 (default).
- ✓ **L2**: Número de subdiretórios no segundo nível. Ex: 256 (default).

Ex:

cache_dir ufs /var/spool/squid 100 16 256

Servidor Proxy

Configuração do servidor

- ☐ **cache_swap_high**

Percentual de utilização do cache que determinará a exclusão de arquivos mais antigos até que o percentual de utilização chegue no percentual determinado pelo parâmetro `cache_swap_low`. Ex: 95 (default).
- ☐ **cache_swap_low**

Percentual de utilização do cache que será utilizado para limitar a exclusão de arquivos mais antigos quando o cache atingir o percentual definido pelo parâmetro `cache_swap_high`. Ex: 90 (default).
- ☐ **visible_hostname**

Nome do servidor que será apresentado nas mensagens de erro.

Servidor Proxy

Configuração do servidor

- Como o arquivo de configuração tem muitas dicas de configuração, é recomendado renomear o arquivo e criar um novo arquivo de configuração.

```
mv /etc/squid/squid.conf /etc/squid/squid.conf.backup
```

Servidor Proxy

Configuração do servidor

- Edite o arquivo **/etc/squid/squid.conf** conforme o conteúdo abaixo:
http_port 3128
visible_hostname servidor
acl todas_redes src all
acl site_google dstdomain www.google.com
acl sites_liberados dstdomain "/etc/squid/sites_liberados.lst"
acl palavras_liberadas url_regex "/etc/squid/palavras_liberadas.lst"
http_access allow site_google
http_access allow sites_liberados
http_access allow palavras_liberadas
http_access deny todas_redes
cache_dir ufs /var/spool/squid 100 16 256
- Salve o arquivo.

Servidor Proxy

Configuração do servidor

- Crie o arquivo **/etc/squid/sites_liberados.lst** com o seguinte conteúdo:

.globo.com

.uol.com.br

.terra.com.br

- Crie o arquivo **/etc/squid/palavras_liberadas.lst** com o seguinte conteúdo:

senac

petrobras

Servidor Proxy

Configuração no servidor

- Ative no firewall a porta 3128 utilizado pelo Squid.

```
firewall-cmd --permanent --add-port=3128/tcp  
firewall-cmd --reload
```

Servidor Proxy

Configuração do servidor

- Reinicie o serviço do Squid.

systemctl restart squid

Servidor Proxy

Configuração do servidor

- Verifique como está o diretório do cache com o comando abaixo:

ls -la /var/spool/squid

- Verifique a quantidade de subdiretórios criados no primeiro e no segundo nível.

Servidor Proxy

Configuração no cliente

- Configure o proxy em um navegador de uma máquina cliente e verifique se os sites www.globo.com, www.uol.com.br e www.terra.com.br estão liberados, além de sites com as palavras configuradas. Os demais sites devem estar bloqueados. Não esqueça de informar a porta 3128 na configuração.
- No Firefox o caminho é o seguinte:
Preferências (Opções) -> Avançado -> Rede -> Configurar Conexão -> Configuração Manual de Proxy
 - ☐ Informar em HTTP: o valor 192.168.20.1
 - ☐ Informar em Porta: o valor 3128
 - ☐ Marcar a caixa “Usar este proxy para todos os protocolos”

Servidor Proxy

Cache

- Execute o comando abaixo no servidor Proxy para verificar os arquivos que estão gravados no cache.

find /var/spool/squid -type f

Servidor Proxy

LOG

- O LOG de acessos no servidor normalmente fica localizado no arquivo **/var/log/squid/access.log**. Execute no servidor Proxy o comando abaixo para verificar os últimos acessos.

tail /var/log/squid/access.log

Servidor Proxy

LOG

- O LOG do cache no servidor normalmente fica localizado no arquivo **/var/log/squid/cache.log**. Execute no servidor Proxy o comando abaixo para verificar os últimos LOGs no cache.

tail /var/log/squid/cache.log

Servidor Proxy

Acesso autenticado

- Consulte os links abaixo para verificar os diversos métodos de autenticação disponíveis.
 - ❑ <https://wiki.squid-cache.org/Features/Authentication>
 - ❑ https://access.redhat.com/documentation/en-us/red_hat_enterprise_linux/7/html/networking_guide/sec-squid-authentication
- Um dos métodos mais simples de autenticação é o NCSA que pode ser consultado abaixo:
 - ❑ http://www.squid-cache.org/Versions/v3/3.1/manuals/ncsa_auth.html

Servidor Proxy

Proxy Transparente

- É a forma de configuração onde não é necessário que o usuário configure o proxy, visto que é feito através do firewall o redirecionamento dos pacotes da porta 80 para a porta do Proxy (porta 3128 no caso do Squid).

Servidor Proxy

Utilitários

- O programa **Sarg** cria relatórios com base nos acessos dos usuários contidos no LOG do Squid.
- O programa **SquidGuard** funciona como um filtro de conteúdo mais rápido para o Squid.
- Pode também ser utilizado o programa **DansGuardian** para realizar filtros com base nos conteúdos dos sites. É personalizável.

Servidor Proxy

Exercícios

- 1) Instale o pacote squid no servidor
- 2) Inicie o serviço squid e coloque-o para iniciar com o boot do sistema.
- 3) Faça um backup do arquivo `/etc/squid/squid.conf`.
- 4) Edite o arquivo `/etc/squid/squid.conf` de forma a liberar alguns sites no servidor Proxy.
- 5) Libere no servidor a porta 3128.
- 6) Reinicie o serviço do Squid.
- 7) Liste o diretório do cache do Squid.
- 8) Configure o proxy em um navegador de uma máquina cliente e verifique se os sites liberados estão acessíveis.
- 9) Liste os arquivos criados no cache do Squid.
- 10) Liste os logs do Squid.

TCP Syslog

TCP Syslog

Conceito

- Recurso utilizado para gerenciamento centralizado de LOGs do sistema, ou seja, sem a necessidade de verificação dos LOGs em cada uma das máquinas da rede.
- Existem diferentes arquivos de log para controlar diferentes informações. O principal log do sistema está localizado no arquivo **/var/log/messages**.

TCP Syslog

Conceito

- Para visualizar os logs do sistema também pode ser utilizado o comando **journalctl** que é gerenciado pelo daemon **journald** que é um componente do sistema de inicialização **systemd**. O comando mantém um pequeno buffer no diretório **/run/log/journal**. O diretório é volátil, ou seja, não é mantido após o boot do sistema.
- Segue a sintaxe do comando:
journalctl [opções]
- As principais opções do comando são:
 - ☐ -x: Quando disponíveis, inclui textos explicativos para os erros apresentados.
 - ☐ -e: Exibe as últimas 1000 linhas de log.

TCP Syslog

Conceito

- Desative a interface enp0s8 no servidor com o comando abaixo:

ifdown enp0s8

- Verifique através dos comandos abaixo a diferença entre consultar diretamente o arquivo de log ou usar o comando journalctl através dos comandos abaixo:

tail /var/log/messages

journalctl -x -e

TCP Syslog

Conceito

- Ative novamente a interface enp0s8 no servidor com o comando abaixo:

ifup enp0s8

Verifique novamente o log através dos comandos citados anteriormente.

tail /var/log/messages

journalctl -x -e

TCP Syslog

Instalação no servidor

- Execute o comando abaixo para instalação do pacote **rsyslog**.

yum install rsyslog

TCP Syslog

Configuração no servidor

- O arquivo de configuração do **TCP Syslog** é o **/etc/rsyslog.conf**. Retire os comentários das linhas abaixo (deixando apenas dos títulos) de forma que o serviço passe a escutar as portas 514/tcp e 514/udp.

Provides UDP syslog reception

\$ModLoad imudp

\$UDPServerRun 514

Provides TCP syslog reception

\$ModLoad imtcp

\$InputTCPServerRun 514

- Para maiores informações sobre a configuração do arquivo **/etc/rsyslog.conf** consultar o link abaixo:

https://access.redhat.com/documentation/pt-br/red_hat_enterprise_linux/7/html/system_administrators_guide/ch-viewing_and_managing_log_files

TCP Syslog

Configuração no servidor

- Para utilizar um porta diferente da 514, configure o SELinux da seguinte forma:

semanage port -a -t syslogd_port_t -p tcp <porta>

- Onde <porta> é o número da porta que está sendo utilizada.

TCP Syslog

Configuração no servidor

- Pode ser utilizado o comando **rsyslogd** para executar algumas operações. Segue a sintaxe do comando:

rsyslogd <opções>

- Seguem algumas opções:
 - ☐ -v: Para ver a versão do rsyslog
 - ☐ -N 1: Para testar o arquivo de configuração.
- Maiores informações sobre o comando podem ser obtidas no link abaixo:

<https://man7.org/linux/man-pages/man8/rsyslogd.8.html>

TCP Syslog

Configuração no servidor

- Execute o comando abaixo para ver a versão do rsyslog.

rsyslogd -v

TCP Syslog

Configuração no servidor

- Execute o comando abaixo para verificar o arquivo de configuração do rsyslog.

rsyslogd -N 1

TCP Syslog

Configuração no servidor

- Reinicie o serviço ou inicie caso ele ainda não esteja ativo.

systemctl restart rsyslog

ou

systemctl start rsyslog

TCP Syslog

Configuração no servidor

- Configure o serviço para que seja inicializado com o boot do sistema.

systemctl enable rsyslog

TCP Syslog

Configuração no servidor

- Ative no firewall as portas 514/tcp e 514/udp utilizado pelo rsyslog.

firewall-cmd --permanent --add-port=514/tcp

firewall-cmd --permanent --add-port=514/udp

firewall-cmd --reload

TCP Syslog

Configuração no servidor

- Execute o comando abaixo para confirmar que o serviço está escutando as portas 514/tcp e 514/udp.

netstat -nlutp | grep 514

TCP Syslog

Configuração no servidor

- Execute o comando abaixo verificar o LOG no servidor de forma contínua.

tail -f /var/log/messages

TCP Syslog

Configuração no cliente

- Instale o pacote **rsyslog** no cliente.

yum install rsyslog

TCP Syslog

Configuração no cliente

- No arquivo de configuração do cliente devem ser adicionadas as regras (*rules*) que indicam quais e para onde os logs devem ser enviados. As regras são compostas pelas **facilities** e pelos **levels (Severity)**. As *facilities* indicam o grupo de logs que devem ser enviados e o *level* o nível de severidade do log que deve ser enviado. Deve ser utilizado o seguinte formato:

`<facility1>.<level1>; <facilityN>.<levelN> <ip, hostname ou arquivo destino>`

- As regras são avaliadas na ordem que aparecem no arquivo. Veja que por padrão as regras são enviadas para arquivos.
- Pode ser utilizado * no lugar da facility ou do level para indicar todas as *facilities* ou todos os *levels*. Também pode ser utilizado a palavra **none** no lugar do *level* para indicar que nenhum log da *facility* seja enviado para o servidor.
- A lista de *facilities* e *levels (security)* pode ser encontrada no link abaixo:

<https://wiki.gentoo.org/wiki/Rsyslog>

TCP Syslog

Configuração no cliente

- Edite o arquivo de configuração **/etc/rsyslog.conf** alterando a linha abaixo:

De:

*.info;mail.none;authpriv.none;cron.none **/var/log/messages**

Para:

*.info;mail.none;authpriv.none;cron.none **@192.168.10.1**

- O @ é para utilizar o protocolo UDP e @@ seria para utilizar o protocolo TCP.
- Assim, esta nova configuração indicará que serão enviadas para o servidor via protocolo UDP todos os logs de **level** igual a **info**, e levels de maior severidade que info, ou seja, de 0 a 5, independente da facility. Entretanto, não serão enviados os logs das facilities **mail**, **authpriv** e **cron**. Veja que existem regras específicas para envio das *facilities* **mail**, **authpriv** e **cron** após esta regra.

TCP Syslog

Configuração no cliente

- Reinicie o serviço ou inicie caso ele ainda não esteja ativo.

systemctl restart rsyslog

ou

systemctl start rsyslog

TCP Syslog

Configuração no cliente

- Configure o serviço para que seja inicializado com o boot do sistema.

systemctl enable rsyslog

TCP Syslog

Teste

- Reinicie o serviço **network** no cliente e verifique o resultado no servidor.

systemctl restart network

- O resultado do comando deve ser apresentado no LOG do servidor.

TCP Syslog

Teste

- Pode ser utilizado o comando **logger** para enviar mensagens de log. Segue a sintaxe do comando:

logger [opções] <mensagem>

- Seguem algumas opções:
 - ☐ -i Exibe o ID do processo.
 - ☐ -t <tag> Enviar uma tag no log.
- Execute o comando abaixo na máquina cliente e verifique a chegada da mensagem no servidor.

logger -i -t teset01 Exemplo de mensagem

TCP Syslog

Exercícios

- 1) Instale o pacote rsyslog no servidor.
- 2) Edite o arquivo `/etc/rsyslog.conf` para ouvir as portas TCP e UDP
- 3) Reinicie o serviço rsyslog.
- 4) Coloque o serviço rsyslog para iniciar com o boot do sistema.
- 5) Ative no firewall as portas 514/tcp e 514/udp utilizado pelo rsyslog.
- 6) Utilize o comando `netstat` para confirmar que o rsyslog está ouvindo as portas 514/tcp e 514/udp.
- 7) Instale o pacote rsyslog em uma máquina cliente.
- 8) Edite o arquivo `/etc/rsyslog.conf` de forma a direcionar alguns logs para o servidor.
- 9) Verifique a configuração do arquivo `/etc/rsyslog` através do comando `rsyslogd`.
- 10) Reinicie o serviço rsyslog e coloque-o para iniciar com o boot do sistema.
- 11) Execute alguma ação na máquina cliente e confirme no servidor que os logs estão sendo recebidos da máquina cliente.



Fecomércio RJ

Sesc | Senac

Detecção de intrusos

Detecção de intrusos

Conceito

- Recurso utilizado para identificação de possíveis tentativas de invasão no sistema. Um dos principais Sistemas de Detecção de Intrusão (IDS) em Linux é o **Fail2ban**.
- Maiores informações sobre o **Fail2ban** podem ser obtidas no link abaixo:

https://www.fail2ban.org/wiki/index.php/Main_Page

Detecção de intrusos

Instalação no servidor

- Execute o comando abaixo para instalação dos pacotes do **Fail2ban**.

yum install epel-release

yum install fail2ban fail2ban-systemd

Detecção de intrusos

Configuração no servidor

- O arquivo de configuração do **Fail2ban** é o **/etc/fail2ban/fail2ban.conf**. As regras de bloqueio ficam contidas no arquivo **/etc/fail2ban/jail.conf**, mas como este arquivo pode ser sobrescrito em uma atualização de pacotes, uma boa prática é criar o arquivo **/etc/fail2ban/jail.local** ou criar arquivos separados no diretório **/etc/fail2ban/jail.d/** para a configuração de cada serviço que será controlado. Desta forma, crie o arquivo **/etc/fail2ban/jail.d/sshd.local** da seguinte forma:

```
[sshd]
enabled = true
port = ssh
action = iptables-multiport
logpath = /var/log/secure
maxretry = 5
bantime = 60
```

- Para maiores detalhes de configuração consulte o link abaixo:
https://www.fail2ban.org/wiki/index.php/MANUAL_0_8

Detecção de intrusos

Configuração do servidor

- Segue a definição dos parâmetros utilizados no arquivo `/etc/fail2ban/jail.d/sshd.local` e mais alguns que podem ser utilizados:

☐	[sshd]	Nome da jail
☐	enabled	Habilita o fail2ban para a jail informada.
☐	port	A porta que será verificada. Neste caso, foi informado ssh no lugar do número da porta.
☐	action	Ação que será realizada. Neste caso, é a criação da regra no iptables.
☐	logpath	Caminho do log que será utilizado. O padrão é <code>/var/log/messages</code> .
☐	maxretry	Número de tentativas permitidas de digitação da senha sem sucesso antes do bloqueio ser criado. O padrão é 3.
☐	findtime	Tempo em segundos que será contado o número de tentativas determinado no parâmetro <code>maxretry</code> . Após este período o contador de tentativas é zerado e serão ermitdas novamente o total de tentativas informadas em <code>maxretry</code> . O padrão é 600.
☐	bantime	Tempo em segundos que a regra permanecerá ativa. Após este período o bloqueio é retirado automaticamente. O padrão é 600.
☐	destemail	E-mail que receberá a notificação de bloqueio.
☐	sender	E-mail que enviará a notificação de bloqueio.

Detecção de intrusos

Configuração no servidor

- Reinicie o serviço ou inicie caso ele ainda não esteja ativo.

systemctl restart fail2ban

ou

systemctl start fail2ban

Detecção de intrusos

Configuração no servidor

- Configure o serviço para que seja inicializado com o boot do sistema.

systemctl enable fail2ban

Detecção de intrusos

Teste

- Acesse o servidor através do SSH em uma máquina cliente e entre com várias senhas erradas até que seja retornada uma mensagem de erro de permissão de acesso.

ssh root@192.168.10.1

Detecção de intrusos

Teste

- Verifique no servidor a regra que foi implementada no iptables através do comando abaixo:

iptables -S | grep -i reject

- Veja que será criada uma regra de bloqueio para a máquina cliente. Esta regra permanecerá por 60 segundos (parâmetro **bantime**) e depois será retirada automaticamente. Se o parâmetro **bantime** fosse um valor negativo a regra ficaria de forma permanente.

Detecção de intrusos

Teste

- Utilize o comando **fail2ban-client** para retirar o banimento antes do tempo limite definido na configuração. Segue a sintaxe do comando:

```
fail2ban-client set <nomedajail> unbanip <endereco ip>
```

- Assim execute o comando abaixo:

```
fail2ban-client set sshd unbanip 192.168.10.2
```

Detecção de intrusos

Teste

- Acesse novamente o servidor através do SSH em uma máquina cliente e verifique que a senha voltará a ser solicitada.

ssh root@192.168.10.1

Detecção de intrusos

Exercícios

- 1) Instale o pacote fail2ban no servidor.
- 2) Configure o serviço SSH para ser controlado pelo Fail2ban.
- 3) Reinicie o serviço fail2ban.
- 4) Coloque o serviço fail2ban para iniciar com o boot do sistema.
- 5) A partir de uma máquina cliente, force alguns erros de conexão com o SSH até dar erro de permissão de acesso.
- 6) Verifique o bloqueio feito nas regras do firewall no servidor.
- 7) Force a retirada do bloqueio.

Módulos PAM

Módulos PAM

Administração de senhas de usuários

- Em distribuições antigas as configurações de senhas ficavam armazenadas no arquivo `/etc/login.defs`. Entretanto, nas distribuições mais recentes muitas aplicações são consideradas **PAM-Aware**, ou seja, usam as configurações contidas nos módulos **PAM (Pluggable Authentication Modules)**. Cada aplicação **PAM-Aware** possui um arquivo de configuração com o mesmo nome localizado no diretório `/etc/pam.d`. Por exemplo, o comando `passwd` utiliza as configurações contidas no arquivo `/etc/pam.d/passwd`.
- Maiores informações sobre módulos PAM podem ser obtidas nos links abaixo:
https://access.redhat.com/documentation/en-us/red_hat_enterprise_linux/7/html/system-level_authentication_guide/pluggable_authentication_modules
https://access.redhat.com/documentation/en-us/red_hat_enterprise_linux/7/html/security_guide/chap-hardening_your_system_with_tools_and_services
https://access.redhat.com/documentation/en-us/red_hat_enterprise_linux/6/html/managing_smart_cards/pam_configuration_files

Módulos PAM

Administração de senhas de usuários

- Para verificar se uma aplicação é **PAM-Aware** execute o comando abaixo para verificar se ele foi compilado com a biblioteca PAM usando o comando ldd.

ldd <caminho completo da aplicação> | grep libpam.so

- Execute o comando abaixo para confirmar que a aplicação passwd é **PAM-Aware**:

ldd /bin/passwd | grep libpam.so

Módulos PAM

Administração de senhas de usuários

- Cada arquivo de configuração de uma aplicação **PAM-Aware** contém um grupo de informações que definem as interfaces, os controles, os módulos e os argumentos a serem utilizados em cada módulo PAM referenciado. O formato de um arquivo de configuração de uma aplicação **PAM-Aware** é o seguinte:

<Nome da interface de módulo> <controle> <nome do módulo> <argumentos do módulo>

Módulos PAM

Administração de senhas de usuários

- A interface define o tipo de ação de autenticação que será feita. As interfaces dos módulos PAM são as seguintes:
 - ☐ **auth** Define o módulo responsável pela verificação da validade da senha.
 - ☐ **account** Define o módulo responsável pela verificação de conta do usuário, como por exemplo, se a conta está expirada ou não.
 - ☐ **password** Define o módulo responsável pela verificação em caso de alteração da senha. Trabalha em conjunto com o módulo auth.
 - ☐ **session** Define o responsável pelo gerenciamento da sessão do usuário, por exemplo, a montagem do diretório home do usuário.

Módulos PAM

Administração de senhas de usuários

- Os controles PAM definem o que fazer com o resultado da verificação do acesso. Os controles PAM são os seguintes:
 - ☐ **required** A autenticação só é realizada caso a verificação do módulo tenha sido com sucesso, mas o usuário só é avisado após todos os módulos referenciados terem sido testados.
 - ☐ **requisite** A autenticação só é realizada caso a verificação do módulo tenha sido com sucesso, mas o usuário é avisado imediatamente em caso de uma falha e o controle é retornado para a aplicação.
 - ☐ **sufficient** O resultado do módulo é ignorado em caso de falha na verificação e em caso de sucesso (e não haja erro anterior de um controle required) o controle é retornado para a aplicação sem a verificação dos demais módulos.
 - ☐ **optional** O resultado do módulo é ignorado. Só é necessário caso não haja outro módulo a ser verificado.
 - ☐ **include** Não está relacionado ao resultado do módulo. Inclui como parâmetro do controle as informações contidas no arquivo referenciado.
 - ☐ **substack** Inclui como parâmetro do controle as informações contidas no arquivo referenciado, mas a avaliação das ações executadas nele não causa o salto completo do restante do módulo, mas apenas do substack.

Módulos PAM

Administração de senhas de usuários

- Execute o comando abaixo para ver o conteúdo do arquivo de configuração PAM da aplicação passwd:

```
cat /etc/pam.d/passwd
```

- Veja que a primeira linha do arquivo contém a interface auth utilizando o controle include para incluir o conteúdo do system-auth. Liste o conteúdo do arquivo com o comando abaixo:

```
cat /etc/pam.d/system-auth
```

Módulos PAM

Administração de senhas de usuários

- Seguem alguns módulos PAM:
 - ☐ **pam_cracklib.so**: módulo para checar a qualidade das senhas no RHEL 6.
 - ☐ **pam_pwquality.so**: módulo para checar a qualidade das senhas no RHEL 7. As configurações de regras de senhas estão contidas no arquivo **/etc/security/pwquality.conf**.
 - ☐ **pam_unix.so**: módulo que verifica a senha usando as informações armazenadas nos arquivos **/etc/passwd** e **/etc/shadow**.
 - ☐ **pam_nologin.so**: módulo que verifica a existência do arquivo **/etc/nologin**, e se existir e o usuário não for root, a autenticação falhará.
 - ☐ **pam_ldap.so**: módulo para autenticação via ldap.
 - ☐ **pam_krb5.so**: módulo para autenticação Kerberos.

Módulos PAM

Administração de senhas de usuários

- Os argumentos a serem utilizados em um módulo PAM dependem do módulo em questão. Por exemplo, os parâmetros do módulo **pam_pwquality.so** podem ser verificadas no arquivo **/etc/security/pwquality.conf**. Os parâmetros podem ser passados como argumentos ou alterados diretamente no arquivo informado.
- Outros parâmetros do módulo **pam_pwquality.so** podem ser verificados no link abaixo:

https://linux.die.net/man/8/pam_pwquality

Módulos PAM

Administração de senhas de usuários

- No RHEL 7 pode ser utilizado o utilitário **pwscore** para checar a qualidade de uma senha com base no módulo **pam_pwquality.so**, conforme o exemplo abaixo:

echo <senha a ser testada> | pwscore

- Seguem alguns utilitários utilizados em outras distribuições:
cracklib-check
pwqcheck

Módulos PAM

Administração de senhas de usuários

- Verifique que o arquivo **/etc/pam.d/passwd** contém a seguinte linha abaixo:

password substack system-auth

- Esta linha chama o arquivo **/etc/pam.d/system-auth** para validar a senha do usuário. Este arquivo contém em uma interface **password** a chamada ao módulo **pam_pwquality.so** para verificar a validade da senha. Altere o parâmetro **retry=3** para **retry=5** e depois tente alterar a senha de um usuário. O sistema aceitará até 5 tentativas de troca da senha e retornará erro ao usuário em caso de erro em todas as tentativas. A tentativa de alteração da senha precisa ser feita com um usuário diferente do usuário root, pois este só ficará limitado caso seja usado o parâmetro **enforce_for_root**.

Módulos PAM

Administração de senhas de usuários

- Verifique que o arquivo **/etc/pam.d/vsftpd** contém uma linha que utiliza o módulo **pam_listfile.so** para consultar o arquivo **/etc/vsftpd/ftpusers** com o objetivo de bloquear o *login* no servidor FTP de usuários contidos no arquivo. Para maiores informações sobre o módulo execute o comando abaixo:

man pam_listfile

Módulos PAM

Administração de senhas de usuários

- Inclua no arquivo **/etc/vsftpd/ftpusers** o usuário **aluno** e tente logar no servidor FTP com este usuário. Veja que não será possível.
- Retire do arquivo **/etc/vsftpd/ftpusers** o usuário **aluno** e tente logar no servidor FTP com este usuário. Veja que agora voltará a ser possível.

Módulos PAM

Administração de senhas de usuários

- Seguem alguém alguns pacotes utilizados para a instalação de módulos PAM.

Para distribuições Red Hat:

☐ **Cracklib**

☐ **Libpwquality**

Para distribuições Debian:

☐ **Libcrack2**

☐ **libpam-cracklib**

Módulos PAM

Bloqueio de login de usuários

- Para bloquear o login de todos os usuários (com exceção do usuário root) crie o arquivo **/etc/nologin**. O arquivo pode ser criado vazio ou com alguma mensagem a ser apresentada aos usuários. A verificação da existência do arquivo é feita pelo módulo **pam_nologin.so**, chamado pelo arquivo **/etc/pam.d/login**.
- Para liberar o acesso dos usuários basta remover o arquivo com o usuário root. O arquivo é removido automaticamente caso seja inicializado o sistema.

Módulos PAM

Exercícios:

- 1) Altere o arquivo de configuração do módulo `pam_pwquality.so` para permitir apenas senhas com 3 caracteres maiúsculos.
- 2) Teste a configuração com o comando `pwscore`.
- 3) Com o usuário `aluno` ativo, tente alterar a senha dele para `Teste` para confirmar que não será possível.
- 4) Com o usuário `root` ativo, altere o arquivo `/etc/pam.d/system-auth` de forma que o usuário `root` também não consiga alterar a senha do usuário `aluno` para `Teste` e também que o número de tentativas fique em 6 vezes.
- 5) Com o usuário `root`, tente alterar a senha do usuário `aluno` para `Teste` para confirmar que a configuração foi bem sucedida. Deve ser exigida a nova senha por 6 vezes.
- 6) Depois retire a configuração e faça a alteração da senha do usuário `aluno` para `Teste` através do usuário `root`.
- 7) Com o usuário `root`, volte a senha do usuário `aluno` para teste.

LDAP

LDAP

Conceito

- O **LDAP (LightWeight Directory Access Protocol)** é um protocolo leve que dá acesso a uma árvore de diretórios chamada **DIT (Directory Information Tree)** que pode conter informações sobre organizações, pessoas, dentre outras. Através dele normalmente são armazenadas informações como usuários e suas respectivas senhas para fornecer um serviço de gerenciamento de identidade e acesso (IAM – Identity Access Management) para a autenticação nas diversas aplicações de uma empresa.
- Ele é derivado do sistema de diretórios X.500 que utilizava o protocolo DAP (Directory Access Protocol) implementado sobre o modelo OSI de 7 camadas.

LDAP

Conceito

- LDAP traz algumas melhorias em relação ao seu antecessor, como por exemplo a eliminação de redundâncias, o que resultou em melhoria de performance. A comunicação é assíncrona, ou seja, pode receber múltiplas requisições e responder em qualquer ordem. Além disso, é implementado sobre o sistema TCP/IP.
- Utilizaremos o programa **Openldap** que trabalha com o protocolo LDAP e implementa o serviço **slapd**. O arquivo de configuração do serviço para aplicações clientes é o **/etc/openldap/ldap.conf**. No servidor os arquivos de configuração ficam contidos no diretório **/etc/openldap/slapd.d/**.
- Consulte os links abaixo para maiores informações sobre as configurações e utilitários do Openldap:

https://access.redhat.com/documentation/pt-br/red_hat_enterprise_linux/7/html/system-level_authentication_guide/openldap

<https://www.openldap.org/doc/admin24/slapdconf2.html>

LDAP

Conceito

- Alguns componentes são importantes no processo de autenticação feito pelo LDAP:
 - ☐ Agente de sistema do diretório (**DSA**): um servidor executando o LDAP na rede
 - ☐ Agente de usuário do diretório (**DUA**): acessar DSAs como cliente (por exemplo, o computador de um usuário)
 - ☐ **DN**: o nome diferenciado com um caminho que passa pela árvore de informações do diretório (DIT) para navegação do LDAP (por exemplo, cn=Susan, ou=users, o=Company)
 - ☐ Nome diferenciado relativo (**RDN**): cada componente no caminho do DN (ex. cn=Susan)

LDAP

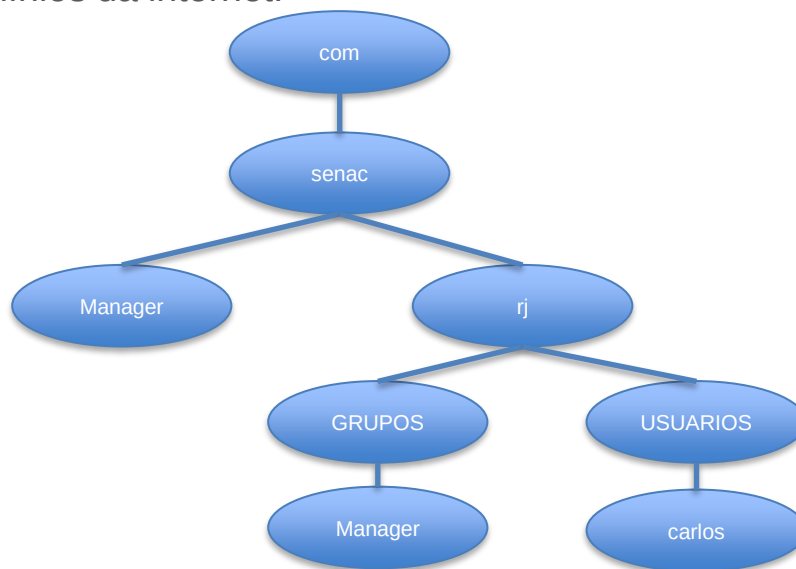
Funcionamento do LDAP



LDAP

DIT

- A DIT (Directory Information Tree) é uma árvore de diretórios organizados de forma hierárquica, onde cada vértice (elipse na figura) é um registro onde são armazenadas as informações. Cada registro possui um identificador único. A parte mais alta da árvore é chamada de raiz. A árvore pode ser organizada de diversas maneiras, mas normalmente são organizadas por estrutura geográfica da empresa ou pelos seus domínios de internet. Segue um exemplo usando domínios da internet.



LDAP

Registros da DIT

- Em cada registro (ou também chamado de entrada) podem ser armazenados atributos e estes dependem das classes de objetos (**object class**) em que eles pertencem. As descrições das classes de objetos ficam em arquivos chamados **schema** (esquema) que determinam quais atributos são obrigatórios ou opcionais para cada classe de objetos. Os schemas ficam localizados na pasta **/etc/ldap/schema**. O principal deles é o arquivo **/etc/ldap/schema/core.schema**.
- Consulte o link abaixo para obter uma lista de atributos utilizados pelo LDAP:
https://access.redhat.com/documentation/pt-br/red_hat_directory_server/11/html/configuration_command_and_file_reference/operational_attributes_special_attributes_and_special_object_classes
- Consulte o link abaixo para obter uma lista dos atributos aceitos pelo esquema padrão do LDAP:
https://access.redhat.com/documentation/pt-br/red_hat_directory_server/11/html/configuration_command_and_file_reference/directory-schema#Directory_Server_Object_Class_Reference

LDAP

Registro da DIT

- Cada registro é identificado unicamente por um DN (Distinguished Name) que é formado por vários RDN (Relative Distinguished Name). Tanto o DN quanto o RDN são identificados através de atributos.

LDAP

Atributos

- Atributos definem o que pode ser armazenado nas entradas (registros) da DIT e dependem das classes de objetos (object classes). Seguem alguns atributos muito utilizados:

☐ dc (domainComponent)	Contém um componente de um nome de domínio.
☐ o (company):	Contém o identificador da empresa.
☐ ou (organizationalUnitName)	Contém o nome de uma unidade organizacional.
☐ uid (userID)	Contém o identificador único de um usuário.
☐ cn (commonName)	Contém o nome de uma entrada. Para entrada de usuários, normalmente é o nome completo da pessoa.

LDAP

Object Classes

- As classes de objetos (**object classes**) determinam os atributos obrigatórios e opcionais de uma entrada (registro) da DIT. Por exemplo, a classe **person** representa uma pessoa.
- Seguem os atributos obrigatórios de serem informados em um registro com esta classe:
 - ☐ cn (commonName)
 - ☐ sn (surname)
- Seguem os atributos opcionais de serem informados em um registro com esta classe:
 - ☐ description
 - ☐ seeAlso
 - ☐ telephoneNumber
 - ☐ userPassword
- Como pode ser visto no arquivo **/etc/openldap/core.schema**, novas classes são criadas a partir da classe **person** através de herança, como é o caso da classe **organizationalPerson** que herda atributos da classe **Person** e adiciona novos atributos.

LDAP

Schema

- Os esquemas (**schema**) definem as classes e seus respectivos atributos obrigatórios. Elas podem ser basicamente de dois tipos:
 - ❑ ABSTRACT Serve para herdar atributos para classes STRUCTURAL.
 - ❑ STRUCTURAL Definem a estrutura básica de atributos obrigatórios e opcionais de uma classe.
 - ❑ AUXILIARY Complementam as classes STRUCTURAL.
- Todo registro da DIT deve ter pelo menos uma classe STRUCTURAL.
- Novos esquemas podem ser adicionados para complementar as informações do LDAP.
- Consulte o link abaixo para maiores informações sobre schema:
https://access.redhat.com/documentation/pt-br/red_hat_directory_server/11/html/administration_guide/extending_the_directory_schema

LDAP

Instalação no servidor

- Para facilitar as configurações, conecte via Putty no servidor e utilize o comando abaixo para fazer a instalação dos pacotes do LDAP.

yum install openldap openldap-clients openldap-servers

yum install nss-pam-ldapd

LDAP

Instalação

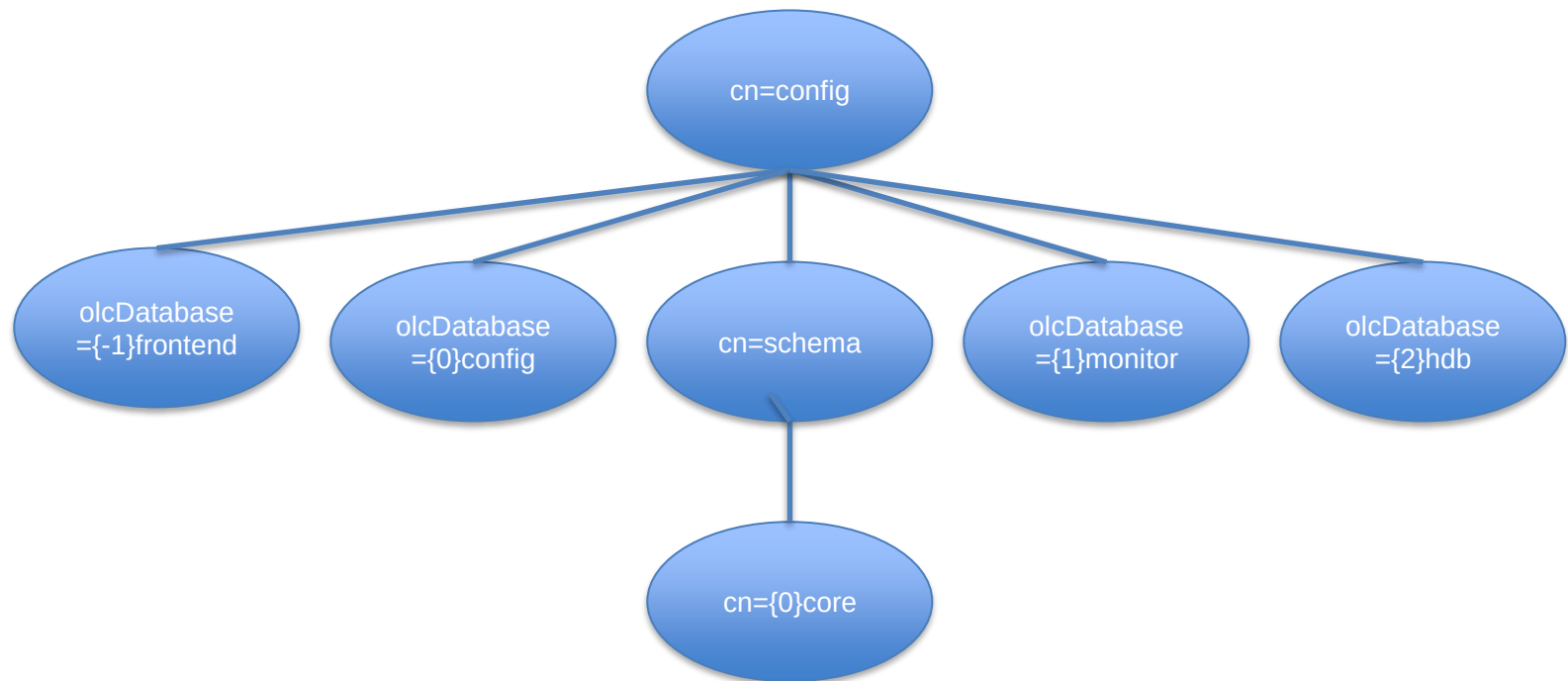
- Configure os booleanos do SELinux para não dar erro na autenticação.

```
setsebool -P allow_yppbind=0 authlogin_nsswitch_use_ldap=0
```

LDAP

DIT de configurações

- As configurações do LDAP ficam armazenadas em uma DIT especial, conforme apresentada abaixo. Este tipo de DIT permite a alteração das configurações sem a necessidade de reiniciar o serviço. O atributo **olcDatabase** significa **on-line configuration Database**.



LDAP

DIT de configurações

- Segue a descrição de cada DN da DIT de configuração:
 - ❑ **cn=config (root):** É baseada em `olcGlobal objectClass` e contém os atributos globais que afetam a operação do slapd.
 - ❑ **cn=schema,cn=config:** Usa a `objectclass olcSchemaConfig` e contém todos os objetos usados pelo sistema `cn=config`.
 - ❑ **cn={Z}xxx,cn=schema,cn=config:** Usa a `objectclass olcSchemaConfig` e contém todos os objetos (atributos e `objectclasses`) definidos pelo esquema específico.
 - ❑ **olcDatabase={Z}xxx,cn=config:** Usa a `objectclass olcDatabaseConfig` (que contém todos os atributos gerais definidos para um banco de dados) mais uma `objectclass` específica do tipo de banco de dados. O valor `{Z}` é uma contagem numérica começando em 0 e `xxxx` é o nome do tipo de banco de dados.

LDAP

Iniciação do serviço

- Por conta da falta de certificado TLS, comente todas as linhas iniciadas por `olcTLS` no arquivo **`/etc/openldap/slapd.d/cn=config.ldif`** para que não apresente erro na inicialização do serviço.

`# olcTLSCACertificatePath: /etc/openldap/certs`

`# olcTLSCertificateFile: "OpenLDAP Server"`

`# olcTLSCertificateKeyFile: /etc/openldap/certs/password`

LDAP

Iniciação do serviço

- Utilize os comandos abaixo para iniciar o serviço do LDAP e configurá-lo para ser iniciado automaticamente com o boot do sistema.

systemctl start slapd

systemctl enable slapd

LDAP

Consulta de registros em uma DIT

- Pode ser utilizado o comando **ldapsearch** para listar o conteúdo de uma DIT.

ldapsearch [opções] ["filtro"]

Onde as opções podem ser:

- | | |
|--|---|
| ☐ -x | Informa que utilizará autenticação simples. |
| ☐ -Y <autenticação> | Informa que utilizará o tipo de autenticação informado. Normalmente utilizada a autenticação EXTERNAL para listar as configurações do LDAP. |
| ☐ -H <servidor> | Especifica o endereço (URI) do servidor. |
| ☐ -b "<dn da árvore>" | Informa o dn da árvore a partir do qual será feita a pesquisa. |
| ☐ "filtro" | Lista de atributos a serem listados. |

LDAP

Consulta de registros em uma DIT

- Utilize o comando abaixo para listar os DN's da DIT contendo as configurações do LDAP.

ldapsearch -Y EXTERNAL -H ldapi:// -b cn=config "dn"

LDAP

Arquivos LDIF

- As configurações no LDAP são feitas através da criação de arquivos LDIF (LDAP Data Interchange Format). Estes arquivos definem o que deve ser incluído, alterado ou excluído de uma DIT.
- Um arquivo LDIF consiste em uma ou mais entradas de diretório separadas por uma linha em branco. Cada entrada LDIF consiste em um ID de entrada opcional, um nome distinto obrigatório, uma ou mais classes de objeto e várias definições de atributo.

LDAP

Inclusão de registros a uma DIT

- Deve ser utilizado o comando **ldapadd** para adicionar registros para uma DIT.

ldapadd [opções] <nome do arquivo .ldif>

Onde as opções podem ser:

- | | |
|--|---|
| ☐ -x | Informa que utilizará autenticação simples. |
| ☐ -Y <autenticação> | Informa que utilizará o tipo de autenticação informado. Normalmente utilizada a autenticação EXTERNAL para listar / atualizar as configurações do LDAP. |
| ☐ -H <servidor> | Especifica o endereço (URI) do servidor. |
| ☐ -D "<dn do usuário>" | Informa o dn do usuário que fará a inclusão |
| ☐ -W | Exibe prompt solicitando a senha do usuário. |
| ☐ -f <nome do arquivo ldif> | Informa o nome do arquivo a ser processado. |

LDAP

Inclusão de registros a uma DIT

- Veja que por padrão o único esquema disponível é o **core**. Execute os comandos abaixo para adicionar novos esquemas na configuração.

```
Idapadd -Y EXTERNAL -H ldapi:/// -f /etc/openldap/schema/cosine.ldif
```

```
Idapadd -Y EXTERNAL -H ldapi:/// -f /etc/openldap/schema/nis.ldif
```

```
Idapadd -Y EXTERNAL -H ldapi:/// -f /etc/openldap/schema/inetorgperson.ldif
```

- Outros esquemas estão disponíveis no diretório **f /etc/openldap/schema/**.

LDAP

Consulta de registros em uma DIT

- Utilize novamente o comando abaixo para listar os DN's da DIT contendo as configurações do LDAP.

ldapsearch -Y EXTERNAL -H ldapi:// -b cn=config "dn"

LDAP

Criação de senha de administrador

- Apesar de ser possível, não devem ser inseridas senhas sem criptografia em arquivos de configuração, assim, deve ser utilizado o comando **slappasswd** para gerar uma senha de administrador do LDAP. Será solicitada uma nova senha e a confirmação desta nova senha. Informe a senha **senac**. Será gerada uma senha criptografada. Copie a senha gerada em um bloco de notas, pois ela será necessária posteriormente.

slappasswd

- O usuário administrador do LDAP por padrão é o usuário **Manager**, mas este pode ser modificado nos arquivos de configuração.

LDAP

Atualização de registros em uma DIT

- Deve ser utilizado o comando **ldapmodify** para modificar registros da DIT.

ldapmodify [opções] <nome do arquivo .ldif>

Onde as opções podem ser:

- ☐ -H Endereço do servidor LDAP.
- ☐ -f <nome do arquivo ldif> Informa o nome do arquivo a ser processado.

LDAP

Atualização de registros em uma DIT

- Segue o layout de um arquivo LDIF para inclusão, alteração ou exclusão de atributos em registros de uma DIT.

dn: <identificador do registro>

changetype: modify

[add|replace|delete]: <nome do atributo>

<atributo a ser incluído ou modificado>: <valor do atributo>

LDAP

Senha do administrador

- Crie um arquivo chamado **manager.ldif** com o conteúdo abaixo para configurar a senha do administrador.

dn: olcDatabase={0}config,cn=config

changetype: modify

add: olcRootPW

olcRootPW: <Cole aqui a senha do administrador>

- Execute a alteração do registro com o comando abaixo:

ldapmodify -H ldapi:/// -f manager.ldif

LDAP

Teste de configuração

- Utilize o comando abaixo para testar a configuração feita.

slaptest -u

LDAP

Configuração

- Criaremos o arquivo **dominio.ldif** da forma abaixo para efetuar a alteração dos registros do domínio da DIT para **senac.com**. Continua no slide seguinte.

```
dn: olcDatabase={1}monitor,cn=config
```

```
changetype: modify
```

```
replace: olcAccess
```

```
olcAccess: {0}to * by dn.base="gidNumber=0+uidNumber=0,cn=peercred,cn=external,cn=auth"
```

```
read by dn.base="cn=Manager,dc=senac,dc=com" read by * none
```

```
dn: olcDatabase={2}hdb,cn=config
```

```
changetype: modify
```

```
replace: olcSuffix
```

```
olcSuffix: dc=senac,dc=com
```

```
dn: olcDatabase={2}hdb,cn=config
```

```
changetype: modify
```

```
replace: olcRootDN
```

```
olcRootDN: cn=Manager,dc=senac,dc=com
```

LDAP

Configuração

dn: olcDatabase={2}hdb,cn=config

changetype: modify

add: olcRootPW

olcRootPW: <Cole a senha do administrador>

dn: olcDatabase={2}hdb,cn=config

changetype: modify

add: olcAccess

olcAccess: {0}to attrs=userPassword,shadowLastChange by

dn="cn=Manager,dc=senac,dc=com" write by anonymous auth by self write by * none

olcAccess: {1}to dn.base="" by * read

olcAccess: {2}to * by dn="cn=Manager,dc=senac,dc=com" write by * read

LDAP

Configuração

- Segue a descrição dos atributos alterados / adicionados:
 - ☐ **olcAccess:** Este atributo concede acesso (especificado por <accesslevel>) a um conjunto de entradas e/ou atributos (especificados por <what>) por um ou mais solicitantes (especificados por <who>).
 - ☐ **olcSuffix:** Este atributo define o sufixo do banco de dados, ou seja, o nome de domínio para o qual o servidor LDAP fornece as informações. Deve ser alterado para o seu nome de domínio.
 - ☐ **olcRootDN:** Este atributo define a entrada de nome distinto (DN) raiz para o usuário que tem acesso irrestrito para executar todas as atividades de administração no LDAP, ou seja, o administrador do LDAP.
 - ☐ **olcRootPW:** Este atributo define a senha do administrador do LDAP.

LDAP

Configuração

- Execute o arquivo **dominio.ldif** com o comando abaixo para modificar os registros:

ldapmodify -H ldapi:/// -f dominio.ldif

LDAP

Configuração

- Segue o layout de um arquivo LDIF para inclusão de registros em uma DIT.

dn: <identificador do registro>

objectClass: <nome de uma classe de objeto1>

objectClass: <nome de uma classe de objetoN>

<atributo1>: <valor do atributo1>

<atributoN>: <valor do atributoN>

LDAP

Configuração

- Crie o arquivo **raiz.ldif** da forma abaixo.

```
dn: dc=senac,dc=com  
objectClass: top  
objectClass: dcObject  
objectclass: organization  
o: senac com  
dc: senac
```

- Execute o arquivo com o comando abaixo:

```
Idapadd -x -D "cn=Manager,dc=senac,dc=com" -W -f raiz.ldif
```

LDAP

Configuração

- Crie o arquivo **manager2.ldif** da forma abaixo.

dn: cn=Manager,dc=senac,dc=com

objectClass: organizationalRole

cn: Manager

description: Administrador

- Execute o arquivo com o comando abaixo:

Idapadd -x -D "cn=Manager,dc=senac,dc=com" -W -f manager2.ldif

LDAP

Configuração

- Crie o arquivo **estrutura.ldif** da forma abaixo.

```
dn: ou=rj,dc=senac,dc=com  
objectClass: organizationalUnit  
ou: rj
```

```
dn: ou=usuarios,ou=rj,dc=senac,dc=com  
objectClass: organizationalUnit  
ou: usuarios
```

```
dn: ou=grupos,ou=rj,dc=senac,dc=com  
objectClass: organizationalUnit  
ou: grupos
```


LDAP

Configuração

- Execute o arquivo **estrutura.ldif** com o comando abaixo:

```
ldapadd -x -D "cn=Manager,dc=senac,dc=com" -W -f estrutura.ldif
```

LDAP

Configuração

- Crie o arquivo **grupo.Idif** da forma abaixo.

```
dn: cn=Manager,ou=grupos,ou=rj,dc=senac,dc=com  
objectClass: posixGroup  
cn: Manager  
gidNumber: 1005
```

- Execute o arquivo com o comando abaixo:

```
Idapadd -x -D "cn=Manager,dc=senac,dc=com" -W -f grupo.Idif
```

LDAP

Configuração

- Crie o arquivo **insere_carlos.ldif** da forma abaixo.

```
dn: uid=carlos,ou=usuarios,ou=rj,dc=senac,dc=com
objectClass: account
objectClass: posixAccount
objectClass: shadowAccount
uid: carlos
userPassword: <Mesma senha do Manager>
cn: carlos
uidNumber: 1001
gidNumber: 1005
homeDirectory: /home/carlos
loginShell: /bin/bash
gecos: carlos
shadowLastChange: 0
shadowMax: 0
shadowWarning: 0
```

LDAP

Configuração

- Execute o arquivo **insere_carlos.ldif** com o comando abaixo:

```
ldapadd -x -D "cn=Manager,dc=senac,dc=com" -W -f insere_carlos.ldif
```

LDAP

Consultas

- Utilize o comando abaixo para listar todos os registros da DIT. Pode também ser utilizado o comando **slapcat**.

```
ldapsearch -x -b "dc=senac, dc=com"  
slapcat
```

- Utilize o comando abaixo para listar todos os registros da DIT que tenha o atributo ou igual a usuarios.

```
ldapsearch -x -b "dc=senac, dc=com" "ou=usuarios"
```

LDAP

Consultas

- Pode ser utilizado o comando **ldapdelete** para apagar registros da DIT.

ldapdelete [opções] [“filtro”]

Onde as opções podem ser:

- ☐ -x Informa que utilizará autenticação simples.
- ☐ -D “<dn do usuário>” Informa o dn do usuário responsável pela deleção.
- ☐ -W Exibe prompt solicitando a senha do usuário.
- ☐ -f <nome do arquivo> Informa o nome do arquivo contendo os dn a serem excluídos. Devem ser informados os dn sem “dn:”.

LDAP

Consultas

- Crie um arquivo chamado **apagar_carlos.Idif** com o conteúdo abaixo:

uid=carlos,ou=usuarios,ou=rj,dc=senac,dc=com

- Execute o comando abaixo para excluir o registro do usuário carlos.

Idapdelete -x -D "cn=Manager,dc=senac,dc=com" -W -f apagar_carlos.Idif

- Execute o comando abaixo para confirmar a exclusão registro do usuário carlos.

Idapsearch -x -b "dc=senac,dc=com" "uid=carlos"

LDAP

Configuração

- Execute novamente o arquivo **insere_carlos.ldif** com o comando abaixo para incluir o usuário carlos:

```
ldapadd -x -D "cn=Manager,dc=senac,dc=com" -W -f insere_carlos.ldif
```

- Execute o comando abaixo para confirmar a inclusão do registro do usuário carlos.

```
ldapsearch -x -b "dc=senac,dc=com" "uid=carlos"
```


LDAP

Liberação de firewall no servidor

- Utilize o comando abaixo para liberar o serviço ldap no firewall do servidor.

```
firewall-cmd --permanent --add-service=ldap  
firewall-cmd --reload
```

LDAP

Instalação no cliente

- Utilize os comandos abaixo para fazer a instalação dos pacotes do LDAP.

yum install openldap openldap-clients

yum install nss-pam-ldapd

yum install nscd

LDAP

Configuração no cliente

- Configure os booleanos do SELinux para não dar erro na autenticação.

```
setsebool -P allow_ypbind=0 authlogin_nsswitch_use_ldap=0
```

LDAP

Configuração no cliente

- Utilize o comando **authconfig** para configurar a autenticação com ldap conforme apresentado abaixo:

```
authconfig --enableldap --enableldapauth --ldapserver=192.168.10.1 --  
ldapbasedn="dc=senac,dc=com" --enablemkhomedir --update
```

- Para maiores informações sobre o comando authconfig consulte o link abaixo:

https://access.redhat.com/documentation/pt-br/red_hat_enterprise_linux/7/html/system-level_authentication_guide/authconfig-install#:~:text=The%20authconfig%20command%2Dline%20tool,settings%20passed%20to%20the%20script.

LDAP

Teste de conexão no cliente

- Utilize o comando **getent** para checar se a máquina cliente já está reconhecendo o usuário carlos.

getent passwd carlos

LDAP

Teste de conexão no cliente

- Autentique com o usuário **carlos** através do comando **su** ou deslogando com **exit**.

su carlos

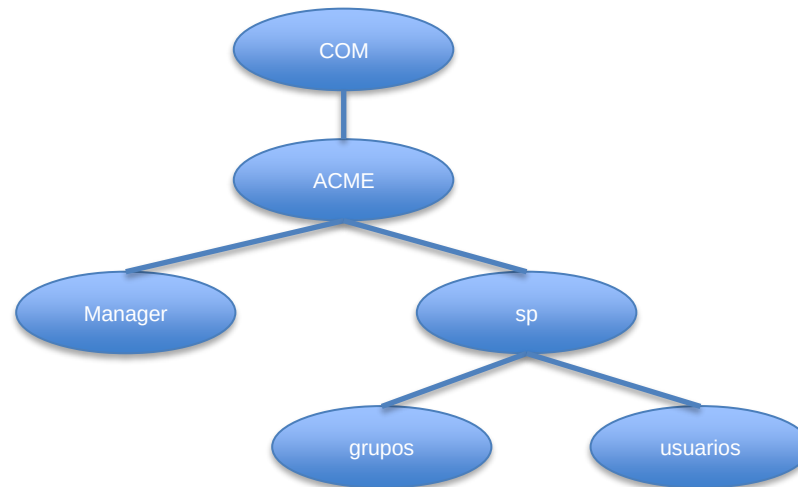
- Execute o comando **id** para confirmar que o usuário contém as informações incluídas no servidor LDAP.

id

LDAP

Exercícios:

1) Configure o LDAP para o domínio acme.com conforme apresentado abaixo:



LDAP

Exercícios:

- 2) Insira dois usuários na DIT.
 - 3) Liste toda a DIT.
 - 4) Exclua um usuário inserido.
 - 5) Liste os usuários da DIT para confirmar que o usuário foi excluído.
 - 6) Configure uma máquina cliente para autenticar no servidor LDAP.
 - 7) Efetue login pela máquina cliente com o usuário que não foi excluído da DIT no servidor.
-

VPN

VPN

Conceito

- **VPN (Virtual Private Network)** é uma rede privada virtual que permite que as informações de uma rede local sejam enviadas por um túnel em uma rede pública.
- Utilizaremos o programa **OpenVPN** que utiliza os protocolos criptográficos **SSL/TLS** para garantir a segurança da conexão.

VPN

Instalação

- Execute os comandos abaixo para instalar os pacotes necessários:

yum install epel-release

yum install openvpn easy-rsa

- O Easy-RSA é uma ferramenta de gerenciamento de infraestrutura de chaves públicas (PKI - Public Key Infrastructure) que será utilizado pelo servidor OpenVPN para gerar uma solicitação de certificado que você irá verificar e assinar no Servidor CA. Para maiores informações sobre Easy-RSA consulte o link abaixo:

<https://community.openvpn.net/openvpn/wiki/EasyRSA3-OpenVPN-Howto>

VPN

Instalação

- Execute o comando abaixo para ver a versão do **OpenVPN** que foi instalada.

openvpn --version

VPN

Configuração no servidor

- Execute o comando abaixo para configurar o SELinux.

setsebool -P daemons_use_tty 1

VPN

Configuração no servidor

- É necessário configurar o arquivo **server.conf** no diretório **/etc/openvpn**. Execute o comando abaixo para confirmar que o diretório contém apenas os subdiretórios **client** e **server** vazios.

ls -laR /etc/openvpn

VPN

Configuração no servidor

- Execute os comandos abaixo para identificar a localização do arquivo de configuração **server.conf** que vem de exemplo junto com a instalação e copiá-lo para o diretório **/etc/openvpn**.

```
find / -name server.conf
```

```
cp /usr/share/doc/openvpn-*/sample/sample-config-files/server.conf /etc/openvpn
```

- Para maiores informações sobre a configuração do OpenVPN consulte os links abaixo:

<https://community.openvpn.net/openvpn/wiki/HOWTO#PushingDHCPoptions-to-clients>

<https://openvpn.net/community-resources/reference-manual-for-openvpn-2-4/>

VPN

Configuração no servidor

- Para criar a infraestrutura necessária para a criação dos certificados, execute os comandos abaixo para copiar os scripts que serão utilizados.

```
mkdir -p /etc/openvpn/easy-rsa/keys
```

```
find / -name easy-rsa
```

```
ls -laR /usr/share/easy-rsa
```

```
cp -rf /usr/share/easy-rsa/3.0/* /etc/openvpn/easy-rsa
```


VPN

Configuração no servidor

- Execute o script de criação da infraestrutura de chaves públicas (PKI). Com a PKI você poderá emitir certificados digitais para autenticar a identidade de usuários, dispositivos ou serviços.

```
cd /etc/openvpn/easy-rsa  
./easyrsa init-pki
```

- Liste o arquivo pki criado.

```
ls -la ./pki
```

VPN

Configuração no servidor

- Execute o comando abaixo para executar o script de criação do certificado **ca.cert**. Ao solicitar a senha, informe **senac** e confirme. Informe **senac** como **Common Name** da organização. Uma autoridade certificadora (CA) é uma organização que atua para validar identidades e vinculá-las a pares de chaves criptográficas com certificados digitais.

./easyrsa build-ca

- Liste o certificado criado.

ls -la ./pki/*.cert

VPN

Configuração no servidor

- Execute o comando abaixo para gerar parâmetros Diffie-Hellman no easy-rsa 3. Ao transmitir o tráfego VPN criptografado, o servidor e os clientes usam a criptografia simétrica, usando os parâmetros Diffie-Hellman para gerar a chave secreta compartilhada entre as partes.

`./easyrsa gen-dh`

- Liste o arquivo criado.

`ls -la ./pki/*.pem`

VPN

Configuração no servidor

- Agora vamos criar uma chave privada para o servidor e um arquivo de pedido de certificado (CSR). Pressione ENTER no Common Name para mantê-lo como servidor.

`./easyrsa gen-req servidor nopass`

- Liste os arquivos criados.

`find . -name servidor.*`

VPN

Configuração no servidor

- Agora vamos assinar o certificado criado. Confirme com **yes** e informe a senha **senac**

./easyrsa sign server servidor

- Liste o certificado criado.

find . -name servidor.crt

VPN

Configuração no servidor

- Altere a permissão e copie os arquivos criados para o diretório **/etc/openvpn**.

```
mkdir /etc/openvpn/keys/
```

```
chmod 750 /etc/openvpn/keys
```

```
cp -a /etc/openvpn/easy-rsa/pki/ca.crt /etc/openvpn/keys/
```

```
cp -a /etc/openvpn/easy-rsa/pki/dh.pem /etc/openvpn/keys/dh2048.pem
```

```
cp -a /etc/openvpn/easy-rsa/pki/issued/servidor.crt /etc/openvpn/keys/
```

```
cp -a /etc/openvpn/easy-rsa/pki/private/servidor.key /etc/openvpn/keys/
```

VPN

Configuração no servidor

- Agora vamos criar uma chave privada para o cliente e um arquivo de pedido de certificado (CSR). Pressione ENTER no Common Name para mantê-lo como **cliente**.

`./easyrsa gen-req cliente nopass`

- Liste os arquivos criados.

`find . -name cliente.*`

VPN

Configuração no servidor

- Agora vamos assinar o certificado criado. Confirme com **yes** e informe a senha **senac**

./easyrsa sign client cliente

- Liste o certificado criado.

find . -name cliente.crt

VPN

Configuração no servidor

- Copie os arquivos criados do cliente para o diretório /etc/openvpn.

```
cp -a /etc/openvpn/easy-rsa/pki/issued/cliente.crt /etc/openvpn/keys/  
cp -a /etc/openvpn/easy-rsa/pki/private/cliente.key /etc/openvpn/keys/
```

VPN

Configuração no servidor

- Configure o arquivo **/etc/openvpn/server.conf** alterando as linhas conforme apresentado abaixo. Utilize o comando ESC / no vi para pesquisar as linhas.

```
push "redirect-gateway def1 bypass-dhcp"  
push "dhcp-option DNS 8.8.8.8"  
push "dhcp-option DNS 8.8.4.4"  
user nobody  
group nobody  
ca /etc/openvpn/keys/ca.crt  
cert /etc/openvpn/keys/servidor.crt  
key /etc/openvpn/keys/servidor.key  
dh /etc/openvpn/keys/dh2048.pem  
push "route 192.168.10.0 255.255.255.0"  
server 10.8.0.0 255.255.255.0  
tls-crypt chave.tlsauth
```

VPN

Configuração no servidor

- Seguem informações sobre os parâmetros utilizados:

push : Fazer o redirecionamento do DHCP, DNS e da rota para o servidor.

user: Define privilégios para usuário. Use nobody para nenhum privilégio de usuário.

group: Define privilégios para grupo. Use nobody para nenhum privilégio de grupo.

ca: Define a localização e nome do arquivo do certificado CA.

cert: Define a localização e nome do arquivo do certificado do servidor.

key: Define a localização e nome do arquivo da chave do servidor.

dh: Define a localização e nome do arquivo que contém a chave secreta Diffie-Hellman p.

server: Define o host da VPN.

tls-crypt: Define a localização e nome do arquivo da chave TLS.

VPN

Configuração no servidor

- Execute o comando abaixo para criar a chave de criptografia TLS.

```
openvpn --genkey --secret /etc/openvpn/chave.tlsauth
```

- Inicie o serviço.

```
systemctl start openvpn@server
```

```
systemctl enable openvpn@server
```

```
systemctl status openvpn@server
```

VPN

Configuração no servidor

- Execute o comando abaixo para ver a criação da interface tun0 que servirá como túnel para a máquina cliente.

ip addr show

- Verifique as rotas que foram criadas.

route -n

VPN

Configuração no servidor

- Copie os arquivos criados para o cliente. Para cada comando informe a senha teste do usuário root da máquina cliente1.

```
scp /etc/openvpn/keys/cliente.* cliente1:/etc/openvpn/
```

```
scp /etc/openvpn/keys/ca.crt cliente1:/etc/openvpn/
```

```
scp /etc/openvpn/chave.tlsauth cliente1:/etc/openvpn/
```

VPN

Configuração no servidor

- Execute os comandos abaixo para incluir a interface tun0.

```
firewall-cmd --permanent --add-interface=tun0  
firewall-cmd --reload
```

VPN

Configuração no servidor

- Execute os comandos abaixo para ativar o serviço **openvpn** no firewall.

```
firewall-cmd --permanent --add-service=openvpn  
firewall-cmd --permanent --add-masquerade  
firewall-cmd --reload
```


VPN

Configuração no servidor

- Execute os comandos abaixo para criar a regra de mascaramento para a subrede da VPN.

```
SHARK=$(ip route get 8.8.8.8 | awk 'NR==1 {print $(NF-2)}')
```

```
firewall-cmd --permanent --direct --passthrough ipv4 -t nat -A  
POSTROUTING -s 10.8.0.0/24 -o $SHARK -j MASQUERADE
```

```
firewall-cmd --reload
```

VPN

Configuração no servidor

- Execute o comando abaixo para que o servidor fique apresentando continuamente o log de mensagens.

tail -f /var/log/messages

VPN

Configuração no cliente

- Instale os pacotes necessários.

yum -y install epel-release

yum -y install openvpn

VPN

Configuração no cliente

- Configure o arquivo **/etc/openvpn/cliente.conf** da seguinte forma:
client
tls-client
dev tun
proto udp
remote 192.168.10.1 1194
resolv-retry infinite
nobind
persist-key
persist-tun
ca /etc/openvpn/ca.crt
cert /etc/openvpn/cliente.crt
key /etc/openvpn/cliente.key
tls-crypt /etc/openvpn/chave.tlsauth

VPN

Configuração no cliente

verb 3

remote-cert-tls server

script-security 2

down /etc/openvpn/client.down

up /etc/openvpn/client.up

topology subnet

user nobody

group nobody

VPN

Configuração no servidor

- Seguem informações sobre os parâmetros utilizados:

tls-client :	Cliente vai usar o protocolo TLS.
dev:	Define o túnel para a VPN.
proto:	Define o protocolo que será utilizado na comunicação.
remote:	Endereço do gateway do servidor VPN e da porta de comunicação.
resolv-retry:	Se a resolução do nome do host falhar para o host indicado em remote, repita a resolução por n segundos antes de falhar. Defina n como "infinito" para tentar novamente indefinidamente.
nobind:	Não vincule ao endereço local e à porta. A pilha IP alocará uma porta dinâmica para retornar pacotes.
persist-key:	Não releia os arquivos de chave em SIGUSR1 ou --ping-restart..
persist-tun:	Não feche e reabra o dispositivo TUN/TAP ou execute scripts up/down em SIGUSR1 ou --ping-restart.
verb:	Define informações de depuração mostrando a transformação de endereços src/dest em pacotes.

VPN

Configuração no servidor

- Seguem informações sobre os parâmetros utilizados:

topology: Configura a topologia de endereçamento virtual ao executar no modo dev tun.

up: Execute script após a abertura bem-sucedida do dispositivo TUN/TAP.

down: Execute o script após o fechamento do dispositivo TUN/TAP.

remote-cert-tls: Exigir que o certificado de mesmo nível tenha sido assinado com um uso de chave explícito e uso de chave estendido com base nas regras RFC3280 TLS.

script-security: Esta diretiva oferece controle em nível de política sobre o uso de programas e scripts externos pelo OpenVPN. A opção 2 permite a chamada de executáveis integrados e scripts definidos pelo usuário.

VPN

Configuração no cliente

- Maiores informações sobre as opções de configuração podem ser obtidas no link abaixo:

<https://openvpn.net/community-resources/reference-manual-for-openvpn-2-4/>

VPN

Configuração no cliente

- Copiar os arquivos **client.down** e **cliente.up** para o diretório **/etc/openvpn**.

```
find /usr -name client.down
```

```
cp /usr/share/doc/openvpn-2.4.12/contrib/pull-resolv-conf/client.down  
/etc/openvpn/
```

```
cp /usr/share/doc/openvpn-2.4.12/contrib/pull-resolv-conf/client.up /etc/openvpn/  
ls -la /etc/openvpn
```

- Alterar permissão de arquivos.

```
chmod 640 /etc/openvpn/cliente.key
```

```
chmod u+x /etc/openvpn/client.down /etc/openvpn/client.up
```

VPN

Configuração no cliente

- Inicie o serviço.

systemctl start openvpn@client

systemctl enable openvpn@client

systemctl status openvpn@cliente

- Execute o comando abaixo para ver a criação da interface tun0 que servirá como túnel para a máquina servidor.

ip addr show

VPN

Configuração no cliente

- Verifique as rotas que foram criadas.

route -n

- Execute um ping para verificar a conectividade com a rota da vpn e a internet.

ping -c3 10.8.0.1

ping www.google.com.br

VPN

Ativação da VPN no cliente

- Ative a VPN.

openvpn --config /etc/openvpn/client.conf

- Verifique se algum erro foi apresentado. Caso não tenha, pressione CTRL + C para parar a execução do comando e reexecute o comando em background conforme apresentado abaixo. O /dev/null é para que a saída do comando não seja exibida no terminal.

openvpn --config /etc/openvpn/client.conf > /dev/null &

- Pode ser utilizado o comando **jobs** para verificar que o programa está em execução em background. Para pará-lo, execute o comando **fg** para retorná-lo ao modo foreground e depois pressione CTRL + C para pará-lo.

VPN

Exercícios:

- 1) Configure uma segunda máquina cliente para a VPN.

Referências

Referências

- SIQUEIRA, L. A. Certificação LPI-2 – 5ª edição. Alta Books, 2018.
- CABRAL, A. L.; SERAGGI, M. R. Redes de computadores: teoria e prática. Senac, 2017.
- SIQUEIRA, L. A. Certificação LPI-1 – 5ª edição. Alta Books, 2015.

Referências

- OLONCA, R. L. Administração de redes Linux: Conceitos e práticas na administração de redes em ambiente Linux. Novatec, 2015.
- NEGUS, C. Linux – A Bíblia –8ª edição. Rio de Janeiro: Alta Books, 2014.
- SILVA, G.; M. Segurança em Sistemas Linux. Rio de Janeiro.2008.

—— Sistema ——

